



THIẾT KẾ VÀ XÂY DỰNG ỨNG DỤNG QUẢN LÝ MẬT KHẨU BẢO MẬT DỰA TRÊN CƠ CHẾ MÃ HÓA PHÍA MÁY KHÁCH VÀ XÁC THỰC BLOCKCHAIN

SINH VIÊN THỰC HIỆN: HOÀNG TIẾN ĐẠT

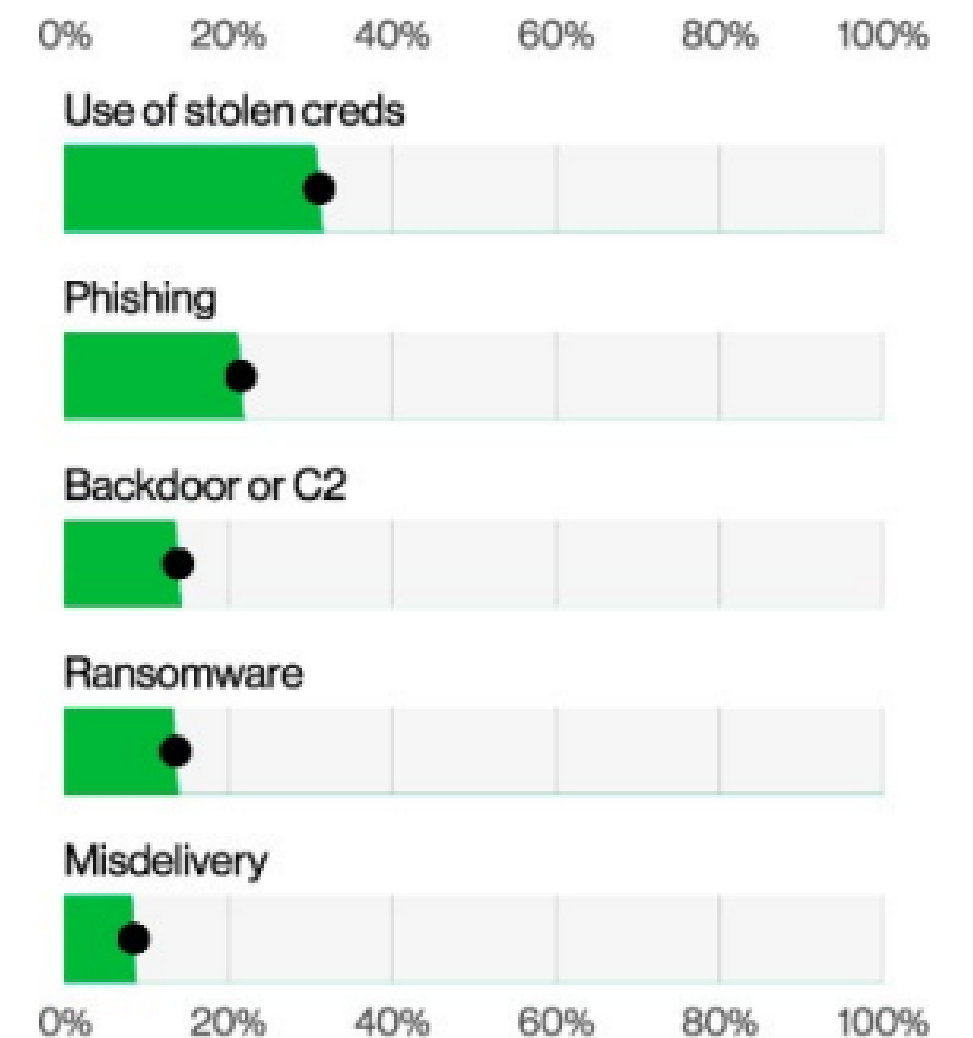
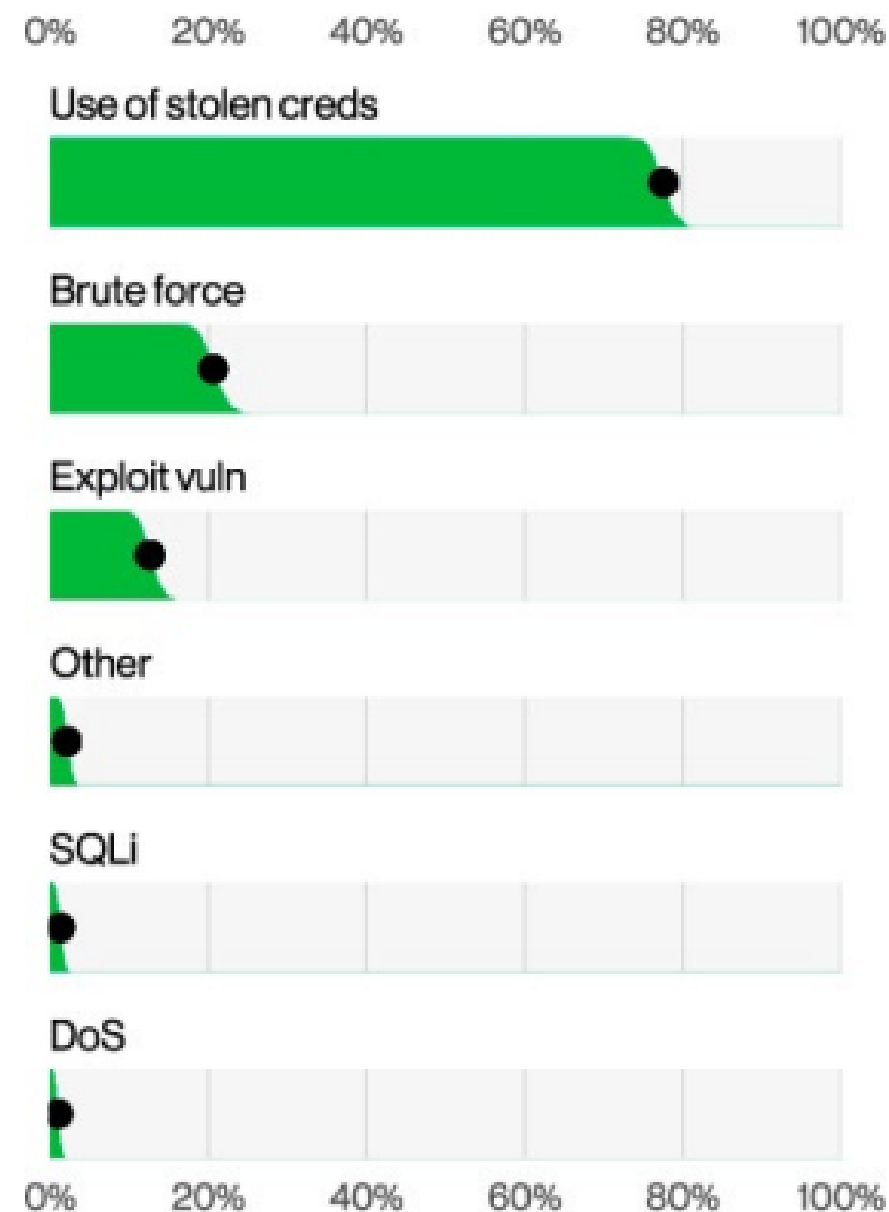
MÃ SINH VIÊN: B23DCCE015

GIẢNG VIÊN: TS. KIM NGỌC BÁCH

GIỚI THIỆU ĐỀ TÀI

Trong bối cảnh chuyển đổi số, đánh cắp thông tin đăng nhập (credential theft) không chỉ là rủi ro tiềm ẩn mà đã trở thành nguyên nhân hàng đầu gây ra các vụ xâm phạm an toàn thông tin quy mô lớn hiện nay

BASIC WEB: 77%



2013 - 2024: 31%

GIỚI THIỆU ĐỀ TÀI

Rủi ro Single Point of Failure
(Điểm yếu tập trung)

Một sự cố bảo mật đơn lẻ tại máy chủ trung tâm có thể dẫn đến rò rỉ dữ liệu mật khẩu trên diện rộng.

Vấn đề về niềm tin
(Trust Issue)

Dù dữ liệu được mã hóa → niềm tin vào một bên thứ ba (bên trung gian) để lưu trữ và quản lý tài sản số nhạy cảm nhất của họ.

MỤC TIÊU ĐỀ TÀI

Giảm sự phụ thuộc hoàn toàn
vào 1 máy chủ trung tâm

Trao quyền quản lý
cho người dùng

Nâng cao nhận thức
người dùng

CÔNG NGHỆ CHÍNH

- **DẪN XUẤT KHÓA: PBKDF2-SHA256**

Sử dụng thuật toán PBKDF2-SHA256 với độ trễ cố ý (310.000 vòng lặp) để sinh khóa CryptoKey từ mật khẩu chủ, giúp chống tấn công Brute-force.

- **MÃ HÓA ĐỐI XỨNG AES-256-GCM**

Thuật toán băm và mã hóa khối (Block Cipher) kích thước 128-bit, sử dụng khóa mã hóa hình học 256-bit qua 14 vòng biến đổi toán học.



$$DK = \text{PBKDF2}(\text{PRF}, \text{Password}, \text{Salt}, c, \text{dkLen})$$

- DK: Khóa dẫn xuất (Derived Key).
- PRF: Hàm giả ngẫu nhiên (Pseudorandom Function).
- Password: Mật khẩu gốc của người dùng.
- Salt: Chuỗi dữ liệu ngẫu nhiên chống tấn công Rainbow Table.
- c: Số lần lặp (Iteration count).
- dkLen: Độ dài khóa dẫn xuất mong muốn.

 **CRYPTO KEY**

CÔNG NGHỆ CHÍNH

MÃ HÓA ĐỐI XỨNG AES-256-GCM

DẪN XUẤT KHÓA: PBKDF2-SHA256

- GCM(GALOIS/COUNTER MODE)

→ IV NGẪU NHIÊN 12-BYTE TRỘN VÀO DỮ LIỆU GỐC

→ AUTH TAG PHÁT HIỆN THAY ĐỔI DỮ LIỆU DÙ 1 BIT

MÃ HÓA

$$C, T = \text{AES-GCM}_{\text{Encrypt}}(\text{CryptoKey}, IV, P)$$

GIẢI MÃ

$$P = \text{AES-GCM}_{\text{Decrypt}}(\text{CryptoKey}, IV, C, T)$$

CÔNG NGHỆ CHÍNH

MÃ HÓA ĐỐI XỨNG AES-256-GCM

DẪN XUẤT KHÓA: PBKDF2-SHA256

Listing 6 Cấu trúc bao gói dữ liệu nén trong store vaultEncrypted

```
{
  "id": "primary",
  "payload": {
    "version": 1,
    "algorithm": "AES-256-GCM",
    "payloadType": "json",
    "iv": "c3VwZXJfaXZfZ2VuZXJhdGVkMTI=",
    "cipherText": "U2FsdGVkX194c2Q4Zjk4...[chuoi base64 do dai lon]..."
  },
  "updatedAt": 1782245231000
}
```


CÔNG NGHỆ CHÍNH

THƯ VIỆN ĐÁNH GIÁ AN TOÀN MẬT KHẨU CỤC BỘ VỚI ZXCVCBN

Do Dropbox phát triển, áp dụng thuật toán mô phỏng trong vai tin tặc (Pattern Matching & Entropy) thay vì chỉ đếm ký tự một cách máy móc và các luật có sẵn

- Nó chứa danh sách đối soát với hơn 40.000 mật khẩu thông dụng, lọc bỏ các tên riêng, từ vựng quen thuộc trên Wikipedia và các từ phổ biến trong nhiều nền văn hóa khác nhau.
- Nó nhận diện được các thói quen đặt mật khẩu yếu của con người như: gõ phím theo hàng (qwertyuiop), lặp lại ký tự (aaa), chuỗi liên tiếp (abcd), ngày tháng, và cả kiểu gõ l33t speak (như dùng số 4 thay cho chữ a, hay số 3 thay cho chữ e) hay là sử dụng thông tin cá nhân của người dùng

=> ĐÁNH GIÁ TRÊN THANG 0-4 DỰA TRÊN ƯỚC LƯỢNG ENTROPY,
ƯU TIÊN SỰ NGẪU NHIÊN, KHÓ ĐOÁN

CÔNG NGHỆ CHÍNH

INDEXEDDB

Cơ sở dữ liệu NoSQL hiệu năng cao tích hợp sẵn trên trình duyệt, lưu trữ bộ đệm bản mã (Ciphertext) hỗ trợ truy xuất nhanh ngoại tuyến (Local-First).

IPFS (MẠNG PHÂN TÁN)

Hệ thống lưu trữ tệp tin ngang hàng (P2P) dựa trên địa chỉ nội dung (Content-Addressing), lưu trữ các gói kết sắt JSON đã mã hóa.

ETHEREUM SEPOLIA (BLOCKCHAIN)

Sổ cái phi tập trung bất biến, lưu trữ con trỏ định danh CID (Content Identifier) của tệp tin trên IPFS để làm bằng chứng toàn vẹn.

CÔNG NGHỆ CHÍNH

INDEXEDDB

IPFS (MẠNG PHÂN TÁN)

Dữ liệu được mã hóa

```
{
  "encryptedPayload": {
    "version": 1,
    "algorithm": "AES-256-GCM",
    "payloadType": "json",
    "iv": "c3VwZXJfaXZfZ2VuZXJhdGVkMTI=",
    "cipherText": "U2FsdGVkX194c2Q4Zjk4..."
  },
  "salt": "dGVzdF9zYWx0XzEyMzQ1Ng=="
}
```

ETHEREUM SEPOLIA (BLOCKCHAIN)

```
struct VaultData {
    string cid;          // Chuoi IPFS CID (do dai tu 46 den 59 ky tu)
    uint256 updatedAt; // Moc thoi gian ghi nhan khoi block.timestamp (tinh
                        ↪ bang giay)
}
```

CID

CÔNG NGHỆ KHÁC

JIT (JUST-IN-TIME) GAS FAUCET SERVER

REACT, VITE, TAILWIND

FIREBASE AUTHENTICATION

ETHERS.JS

NODE JS

HARDHAT

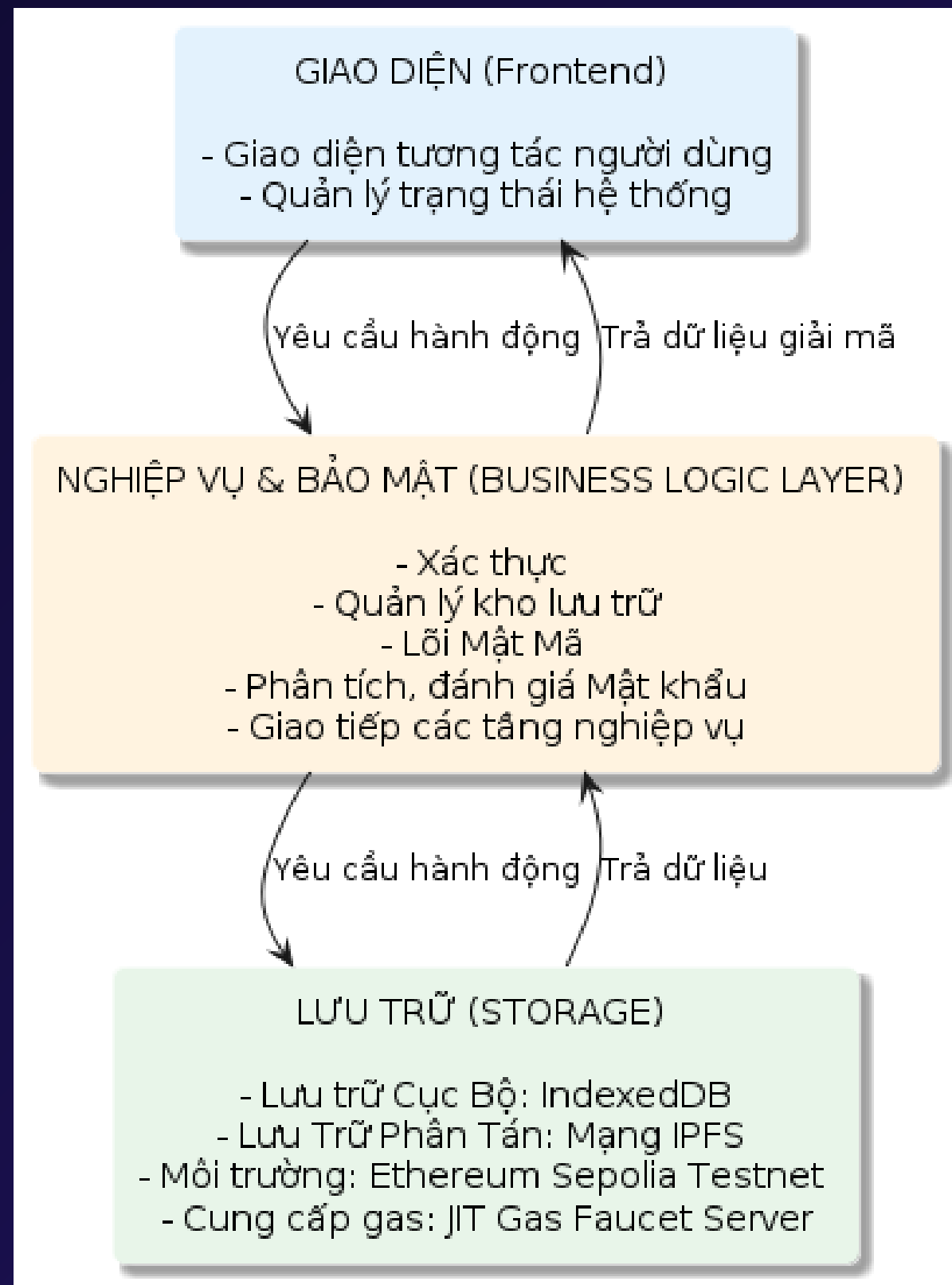
NPM

ETHERS.JS

METAMASK EXTENSION

SOLIDITY

TỔNG QUAN HỆ THỐNG



CHỨC NĂNG

- UC1: Đăng nhập với google hoặc ví metamask
- UC2: Đăng ký với google hoặc ví metamask
- UC3: Thêm mật khẩu mới
- UC4: Sửa thông tin mật khẩu
- UC5: Xóa mật khẩu
- UC6: Tạo mật khẩu mạnh ngẫu nhiên
- UC7: Xuất dữ liệu (Export JSON)
- UC8: Nhập dữ liệu (Import JSON)
- UC9: Xóa toàn bộ dữ liệu kho lưu trữ
- UC10: Báo cáo bảo mật
- UC11: Đổi mật khẩu chủ (Master Password)
- UC12: Cập nhật thông tin cá nhân

THỬ NGHIỆM HỆ THỐNG

Bước	Thời gian trung bình	Ghi chú
Upload IPFS (Pinata)	~1–3 giây	Phụ thuộc kích thước payload và băng thông mạng
Ghi CID lên blockchain	~15–30 giây	Phụ thuộc tốc độ xác nhận block trên Sepolia
Đọc CID từ blockchain	< 1 giây	Hàm view, không tốn phí gas
Tải dữ liệu từ IPFS	~1–2 giây	Qua IPFS Gateway của Pinata
Tổng luồng đồng bộ	~20–40 giây	Từ lúc nhấn “Lưu” đến xác nhận blockchain

Kiểm tra	Mô tả	Kết quả
Master Password trên Network	Kiểm tra tất cả request HTTP/HTTPS trong Dev-Tools Network tab	Không tìm thấy
Plaintext mật khẩu trên IPFS	Kiểm tra payload POST tới Pinata API	Chỉ chứa ciphertext
Dữ liệu nhạy cảm trên blockchain	Kiểm tra event logs trên Etherscan	Chỉ chứa CID pointer
Khóa mã hóa trong localStorage	Kiểm tra toàn bộ Local Storage	Không lưu khóa mã hóa

STT	Chức năng / Tiêu chí thử nghiệm	Kết quả
1	Mã hóa AES-256-GCM + PBKDF2 dữ liệu kết sắt cục bộ	Đạt
2	Lưu trữ Master Password dạng verifier (không plaintext)	Đạt
3	Giao diện CRUD quản lý mật khẩu	Đạt
4	Đánh giá cường độ mật khẩu bằng zxcvbn	Đạt
5	Sinh mật khẩu ngẫu nhiên an toàn	Đạt
6	Kết nối ví MetaMask trên mạng Sepolia	Đạt
7	Đăng nhập Google và sinh ví ảo tự động	Đạt
8	JIT Gas Station Faucet tài trợ phí gas	Đạt
9	Biên dịch và triển khai Smart Contract VaultPointer	Đạt
10	Upload/Download dữ liệu mã hóa qua IPFS (Pinata)	Đạt
11	Ghi/Đọc CID pointer trên blockchain	Đạt
12	Đồng bộ xuyên thiết bị (Cross-Device Sync)	Đạt
13	Auto-Lock và quản lý session key trên RAM	Đạt
14	Đổi Master Password (Key Rotation)	Đạt
15	Nhập/Xuất dữ liệu (Import/Export)	Đạt
16	Xử lý lỗi và tình huống ngoại lệ	Đạt
17	Bảo mật dữ liệu trên đường truyền	Đạt
18	Hiệu năng mã hóa/giải mã với 200 bản ghi	Đạt
19	Triển khai Docker Container	Đạt
20	Tương thích ngược dữ liệu cũ (legacy format)	Đạt

ƯU VÀ NHƯỢC ĐIỂM

Đảm bảo an toàn dữ liệu

Cải thiện trải nghiệm
người dùng phổ thông

Đảm bảo quyền
sở hữu dữ liệu

Đảm bảo dữ liệu khi
quá trình lưu lỗi

Thời gian xử lý lâu

Còn phụ thuộc trung gian

Thiếu cơ chế giải quyết chi phí
gas khi lên mainnet

Chưa hỗ trợ backup

HƯỚNG PHÁT TRIỂN

TÍCH HỢP GIẢI PHÁP LAYER 2

PHÁT TRIỂN CHIA SẺ MẬT KHẨU

TỰ ĐỘNG ĐIỀN MẬT KHẨU

TRIỂN KHAI THÀNH APP

QUÉT RÒ RỈ HIBP VÀ AI HỖ TRỢ





MINIMIN VAULT

THANK FOR
LISTENING
